

JHU AI Engineering

Module 9 - WebSec Application Container Security

Part 1: Installing Docker

```
[2026-07-17 14:15:36] [ft@nostromo] [~/Documents/code/jhu/jhu-ai-eng-course/module9]
$ docker run hello-world
Unable to find image 'hello-world:latest' locally
latest: Pulling from library/hello-world
4f55086f7dd0: Pull complete
Digest: sha256:c3cbe1cc1aa588a64951ac6286e0df7b27fe2e6324b1001c619bb358770c0178
Status: Downloaded newer image for hello-world:latest

Hello from Docker!
This message shows that your installation appears to be working correctly.

To generate this message, Docker took the following steps:
1. The Docker client contacted the Docker daemon.
2. The Docker daemon pulled the "hello-world" image from the Docker Hub.
   (amd64)
3. The Docker daemon created a new container from that image which runs the
   executable that produces the output you are currently reading.
4. The Docker daemon streamed that output to the Docker client, which sent it
   to your terminal.

To try something more ambitious, you can run an Ubuntu container with:
$ docker run -it ubuntu bash

Share images, automate workflows, and more with a free Docker ID:
https://hub.docker.com/

For more examples and ideas, visit:
https://docs.docker.com/get-started/
```

A screenshot demonstrating a running `docker hello-world`! [\[1\]](#)

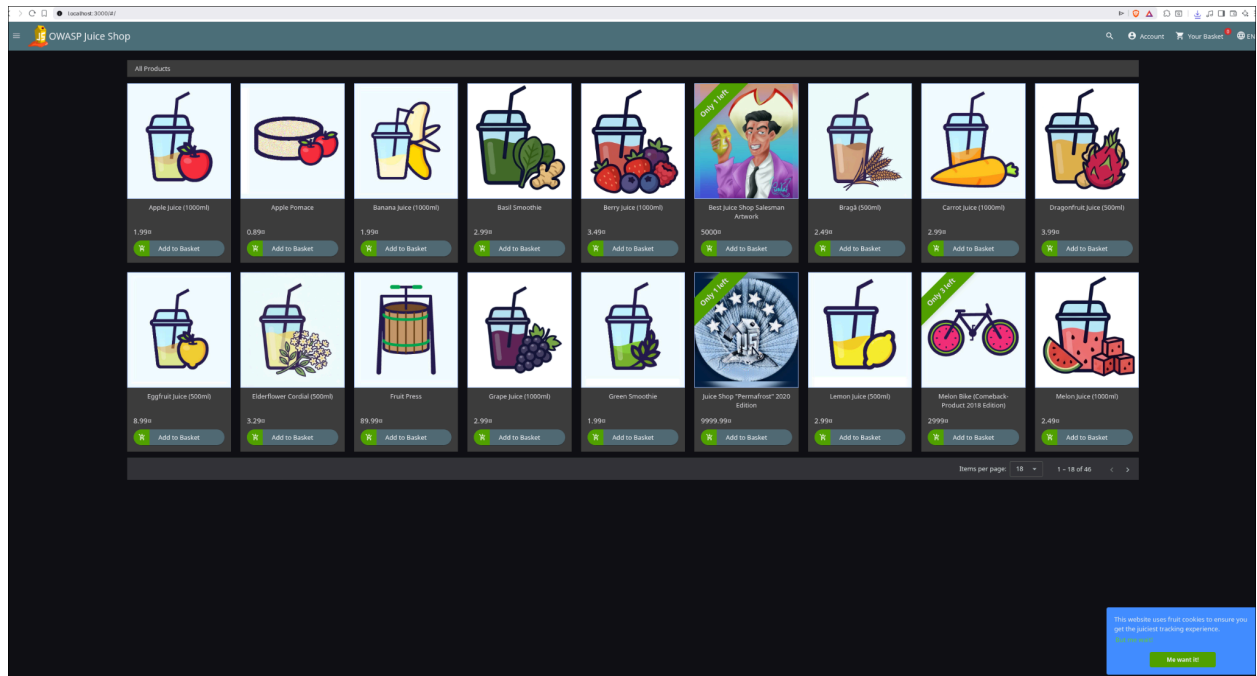
Part 2: OWASP Juice Shop

```
[2026-07-17 14:16:59] [ft@nostromo] [~/Documents/code/jhu/jhu-ai-eng-course/module9]
$ docker pull bkimminich/juice-shop
Using default tag: latest
latest: Pulling from bkimminich/juice-shop
47de5dd0b812: Pull complete
c172f21841df: Pull complete
99515e7b4d35: Pull complete
99ba982a9142: Pull complete
d6b1b89eccac: Pull complete
2780920e5dbf: Pull complete
7c12895b777b: Pull complete
3214acf345c0: Pull complete
52630fc75a18: Pull complete
dd64bf2dd177: Pull complete
b839d9ae01f6: Pull complete
ebddc55facdc: Pull complete
bdfd7f7e5bf6: Pull complete
2d4d7adf6272: Pull complete
cf397222899a: Pull complete
bd8962e29291: Pull complete
cac2ae0193cb: Pull complete
dd0d9bfd3bee: Pull complete
7cc70dfd88cf: Pull complete
8224d91da70b: Pull complete
1a4be5562d92: Pull complete
702a7246bd56: Pull complete
48fce22aed6d: Pull complete
6b2d9fb43c80: Pull complete
Digest: sha256:e68144772ebaaca0ec117b38d44903af92416793230288ef7c5437fc4f26850a
Status: Downloaded newer image for bkimminich/juice-shop:latest
docker.io/bkimminich/juice-shop:latest
```

A screenshot showing the install of the docker container `bkimminich/juice-shop` [2]

```
[2026-07-17 14:19:16] [ft@nostromo] [~/Documents/code/jhu/jhu-ai-eng-course/module9]
$ docker run --rm -p 3000:3000 bkimminich/juice-shop
info: Detected Node.js version v24.17.0 (SUCCESS)
info: Detected OS linux (SUCCESS)
info: Detected CPU x64 (SUCCESS)
info: Configuration default validated (SUCCESS)
info: Entity models 21 of 21 are initialized (SUCCESS)
info: All dependencies in ./package.json are satisfied (SUCCESS)
info: Required file server.js is present (SUCCESS)
info: Required file styles.css is present (SUCCESS)
info: Required file index.html is present (SUCCESS)
info: Required file main.js is present (SUCCESS)
info: Required file polyfills.js is present (SUCCESS)
info: Required file matching /^hacking-instructor-.*\.js$/ is present (SUCCESS)
info: Port 3000 is available (SUCCESS)
info: Domain https://www.alchemy.com/ is reachable (SUCCESS)
warn: Environment variable ALCHEMY_API_KEY is not present (WARNING)
warn: "Mint the Honey Pot" challenge will not work as intended without a valid ALCHEMY_API_KEY
warn: "Wallet Depletion" challenge will not work as intended without a valid ALCHEMY_API_KEY
info: Check https://howto-web3.owasp-juice.shop for instructions on how to set up and configure the Alchemy API
warn: Domain http://localhost:11434/v1 is not reachable (WARNING)
warn: "Chatbot Prompt Injection" challenge will not work as intended without access to http://localhost:11434/v1
warn: "Greedy Chatbot Manipulation" challenge will not work as intended without access to http://localhost:11434/v1
warn: "AI Debugging" challenge will not work as intended without access to http://localhost:11434/v1
warn: "System Prompt Extraction" challenge will not work as intended without access to http://localhost:11434/v1
info: Check https://howto-llm.owasp-juice.shop for instructions on how to set up and configure the LLM API
info: Server listening on port 3000
```

A screenshot of the running `juice-shop` server on `localhost:3000`



A screenshot of the running juice-shop website served on localhost:3000

```
[2026-07-17 14:26:10] [ft@nostromo] [~/Documents/code/jhu/jhu-ai-eng-course/module9/lab]
$ ./grype version
Application:      grype
Version:         0.116.0
BuildDate:      2026-07-16T16:43:45Z
GitCommit:      3b014b00097d43933e5cce485e744db8289a406f
GitDescription:  v0.116.0
Platform:       linux/amd64
GoVersion:      go1.26.3
Compiler:       gc
Syft Version:   v1.48.0
Supported DB Schema: 6
```

Part 4: Scanning Images

[illegible]

Fred Teumer

```
[2026-07-17 14:36:46] [ft@nostromo] [-/Documents/code/jhu/jhu-ai-eng-course/module9/lab]
$ ./grype dir:~/Documents/code/jhu/jhu-ai-eng-course/module5/.venv | grep 'Medium|Critical' | more
✓ Indexed file system
  /home/ft/Documents/code/jhu/jhu-ai-eng-course/module5/.venv
✓ Cataloged contents
  ✓ Packages [822 packages]
  ✓ Executables [286 executables]
  ✓ File metadata [2,074 locations]
  ✓ File digests [2,074 files]
✓ Scanned for vulnerabilities [79 vulnerability matches]
  by severity: 3 critical, 34 high, 26 medium, 7 low, 7 negligible
  by status: 59 fixed, 16 not-fixed, 0 ignored
[0000] WARN no explicit name and version provided for directory source, deriving artifact ID from the given path (which is not ideal) from=s
[0003] ERROR unable to parse yarn v2 package key from=syft key=__metadata
[0003] ERROR unable to parse yarn v2 package key from=syft key=__metadata
[0003] ERROR unable to parse yarn v2 package key from=syft key=__metadata
litellm 1.83.0 1.83.7 python GHSA-r75f-5x8p-qvmc Critical 86.6% (99th) 97.4 (kev)
handlebars 4.7.8 4.7.9 npm GHSA-2w6w-674q-4c4q Critical 1.8% (75th) 1.7
lodash 4.17.21 4.17.23 npm GHSA-xxjr-mmjv-4pgp Medium 1.5% (72nd) 0.9
tar 6.1.11 6.2.1 npm GHSA-f5x3-32g6-xq36 Medium 0.9% (56th) 0.5
sanitize-html 2.7.3 2.12.1 npm GHSA-rm97-x556-q36h Medium 1.0% (59th) 0.5
litellm 1.83.0 1.84.0 python GHSA-4xpc-pv4p-pm3w Critical 0.6% (42nd) 0.5
ws 8.17.1 8.20.1 npm GHSA-58qx-3vcg-4xpx Medium 0.7% (50th) 0.4
diskcache 5.6.3 python GHSA-w8v5-vhqg-4h9v Medium 0.5% (40th) 0.3
ajv 6.12.6 6.14.0 npm GHSA-2g4f-4pwh-qvx6 Medium 0.5% (38th) 0.3
ajv 8.12.0 8.18.0 npm GHSA-2g4f-4pwh-qvx6 Medium 0.5% (38th) 0.3
ajv 8.17.1 8.18.0 npm GHSA-2g4f-4pwh-qvx6 Medium 0.5% (38th) 0.3
brace-expansion 1.1.11 1.1.13 npm GHSA-f886-m6hf-6m8v Medium 0.4% (34th) 0.2
brace-expansion 2.0.1 2.0.3 npm GHSA-f886-m6hf-6m8v Medium 0.4% (34th) 0.2
js-yaml 3.14.1 3.14.2 npm GHSA-mh29-5h37-fv8m Medium 0.4% (33rd) 0.2
qs 6.13.0 6.14.1 npm GHSA-6rx7-vpxm-498p Medium 0.4% (33rd) 0.2
qs 6.14.0 6.14.1 npm GHSA-6rx7-vpxm-498p Medium 0.4% (33rd) 0.2
uuid 8.3.2 11.1.1 npm GHSA-w5hq-g745-h8pq Medium 0.3% (25th) 0.2
qs 6.13.0 6.15.2 npm GHSA-q8mj-m7cp-5q26 Medium 0.4% (27th) 0.2
qs 6.14.0 6.15.2 npm GHSA-q8mj-m7cp-5q26 Medium 0.4% (27th) 0.2
lodash 4.17.21 4.18.0 npm GHSA-f23m-r3pf-42rh Medium 0.3% (23rd) 0.2
handlebars 4.7.8 4.7.9 npm GHSA-2qvq-rjwj-gvw9 Medium 0.3% (19th) 0.1
js-yaml 3.14.1 3.15.0 npm GHSA-h67p-54hq-tp68 Medium 0.3% (17th) 0.1
js-yaml 4.1.1 4.2.0 npm GHSA-h67p-54hq-tp68 Medium 0.3% (17th) 0.1
```

A screenshot of *more* of a *grype* scan on the Juice Shop container.

```
[2026-07-17 14:52:32] [ft@nostromo] [-/Documents/code/jhu/jhu-ai-eng-course/module9/lab]
$ ./grype dir:~/Documents/code/jhu/jhu-ai-eng-course/module5/.venv | grep 'Medium|Critical' | more
✓ Indexed file system
  /home/ft/Documents/code/jhu/jhu-ai-eng-course/module5/.venv
✓ Cataloged contents
  ✓ Packages [1,675 packages]
  ✓ Executables [156 executables]
  ✓ File metadata [490 locations]
  ✓ File digests [490 files]
✓ Scanned for vulnerabilities [71 vulnerability matches]
  by severity: 3 critical, 35 high, 26 medium, 7 low, 0 negligible
  by status: 69 fixed, 2 not-fixed, 0 ignored
[0000] WARN no explicit name and version provided for directory source, deriving artifact ID from the given path (which is not ideal) from=s
[0003] ERROR unable to parse yarn v2 package key from=syft key=__metadata
[0003] ERROR unable to parse yarn v2 package key from=syft key=__metadata
[0003] ERROR unable to parse yarn v2 package key from=syft key=__metadata
litellm 1.83.0 1.83.7 python GHSA-r75f-5x8p-qvmc Critical 86.6% (99th) 97.4 (kev)
handlebars 4.7.8 4.7.9 npm GHSA-2w6w-674q-4c4q Critical 1.8% (75th) 1.7
lodash 4.17.21 4.17.23 npm GHSA-xxjr-mmjv-4pgp Medium 1.5% (72nd) 0.9
tar 6.1.11 6.2.1 npm GHSA-f5x3-32g6-xq36 Medium 0.9% (56th) 0.5
sanitize-html 2.7.3 2.12.1 npm GHSA-rm97-x556-q36h Medium 1.0% (59th) 0.5
litellm 1.83.0 1.84.0 python GHSA-4xpc-pv4p-pm3w Critical 0.6% (42nd) 0.5
ws 8.17.1 8.20.1 npm GHSA-58qx-3vcg-4xpx Medium 0.7% (50th) 0.4
diskcache 5.6.3 python GHSA-w8v5-vhqg-4h9v Medium 0.5% (40th) 0.3
ajv 6.12.6 6.14.0 npm GHSA-2g4f-4pwh-qvx6 Medium 0.5% (38th) 0.3
ajv 8.12.0 8.18.0 npm GHSA-2g4f-4pwh-qvx6 Medium 0.5% (38th) 0.3
ajv 8.17.1 8.18.0 npm GHSA-2g4f-4pwh-qvx6 Medium 0.5% (38th) 0.3
brace-expansion 1.1.11 1.1.13 npm GHSA-f886-m6hf-6m8v Medium 0.4% (34th) 0.2
brace-expansion 2.0.1 2.0.3 npm GHSA-f886-m6hf-6m8v Medium 0.4% (34th) 0.2
js-yaml 3.14.1 3.14.2 npm GHSA-mh29-5h37-fv8m Medium 0.4% (33rd) 0.2
qs 6.13.0 6.14.1 npm GHSA-6rx7-vpxm-498p Medium 0.4% (33rd) 0.2
qs 6.14.0 6.14.1 npm GHSA-6rx7-vpxm-498p Medium 0.4% (33rd) 0.2
uuid 8.3.2 11.1.1 npm GHSA-w5hq-g745-h8pq Medium 0.3% (25th) 0.2
qs 6.13.0 6.15.2 npm GHSA-q8mj-m7cp-5q26 Medium 0.4% (27th) 0.2
qs 6.14.0 6.15.2 npm GHSA-q8mj-m7cp-5q26 Medium 0.4% (27th) 0.2
lodash 4.17.21 4.18.0 npm GHSA-f23m-r3pf-42rh Medium 0.3% (23rd) 0.2
handlebars 4.7.8 4.7.9 npm GHSA-2qvq-rjwj-gvw9 Medium 0.3% (19th) 0.1
js-yaml 3.14.1 3.15.0 npm GHSA-h67p-54hq-tp68 Medium 0.3% (17th) 0.1
js-yaml 4.1.1 4.2.0 npm GHSA-h67p-54hq-tp68 Medium 0.3% (17th) 0.1
```

A screenshot of *more* of a *grype* scan on the dependencies used to complete Module 5.

Note: I chose this as I do not want to run this scan against my entire machine, as I do not trust *grype* (it's a random binary from the internet).

Part 5: Vulnerability Analysis

I pulled two vulnerabilities out of the Juice Shop scan to look at more closely: one from the application's own `npm` dependencies and one from the Debian base image underneath it so I could see how Gripe handles both layers of the image.

5.1 The two vulnerabilities

CVE-2015-9235 (`jsonwebtoken`, `npm`). Gripe flagged `jsonwebtoken` 0.1.0 as Critical, and it had the highest exploit likelihood in the whole scan (EPSS 8.7%, 94th percentile). It's a JWT algorithm-confusion bug in every version before 4.2.2: because the library doesn't lock down which algorithm it accepts at verification time, an attacker can take a server that expects an RS256 (asymmetric) token and instead send an HS256 token signed with the server's own public key as the HMAC secret. The library happily validates it, and the attacker can forge tokens for any user (admin included) without ever seeing the private key. For an app like Juice Shop that runs its auth on JWTs, that's about as bad as it gets [\[4\]\[5\]\[6\]](#).

CVE-2026-5450 (`libc6` / `glibc`, Debian). This one sits down in the OS layer, and Gripe marked it "won't fix" – there's no patched Debian package available. It's a one-byte heap overflow in `glibc`'s `scanf` functions (versions 2.7 through 2.43) when `%mc` is used with a width over 1024, and CISA scores it 9.8 with a worst case of remote code execution [\[7\]\[8\]](#). Worth noting, though: its EPSS was only 0.5%, and neither CVE currently shows up in CISA's Known Exploited Vulnerabilities catalog [\[9\]](#).

5.2 Analysis

What stood out to me is that Gripe found problems at two completely different layers (822 packages cataloged, 75 matches total; 7 critical, 34 high) [\[3\]](#) split between the `npm` dependencies and the Debian base image. That matters because you fix them differently: the `npm` findings go away by bumping versions, but the `glibc` finding only clears if you rebuild on a patched base image. The scan also made me pay attention to the gap between severity and actual risk. Both CVEs I picked are Critical, but the JWT bug sits near the 94th EPSS percentile and is trivially weaponized, while the `glibc` bug is at the 39th and Debian didn't even bother patching it. Severity alone would tell me to treat them the same; EPSS and the KEV catalog tell me they're not the same at all. The good news is that 59 of the 75 findings already have a fix available, so most of this is just badly outdated versions (`jsonwebtoken` pinned at 0.1.0 when the fix landed back at 4.2.2) rather than anything genuinely unpatchable.

5.3 Would I run this in production?

No, and it's not close. Juice Shop is intentionally vulnerable: it's OWASP's training target [\[2\]](#), built to be attacked. It has no business anywhere near production to begin with. But even ignoring that, the scan alone would kill it: a Critical auth-bypass in the exact library handling its tokens, plus a Critical, unpatchable RCE in the base image. If this were a real service I cared about, I'd bump the fixable dependencies, rebuild on a minimal patched base image, and wire Gype into CI so a build fails the moment a new Critical shows up. As it stands, this image belongs in a lab, not in production.

References

1. Docker Inc. "Install Docker Engine on Ubuntu." Docker Docs. <https://docs.docker.com/engine/install/ubuntu/> (accessed July 17, 2026).
2. OWASP Foundation. "OWASP Juice Shop." OWASP. <https://owasp.org/www-project-juice-shop/> (accessed July 17, 2026).
3. Anchore, Inc. "Grype: A Vulnerability Scanner for Container Images and Filesystems." GitHub. <https://github.com/anchore/grype> (accessed July 17, 2026).
4. GitHub Advisory Database. "Verification Bypass in jsonwebtoken (GHSA-c7hr-j4mj-j2w6 / CVE-2015-9235)." GitHub. <https://github.com/advisories/GHSA-c7hr-j4mj-j2w6> (accessed July 17, 2026).
5. National Institute of Standards and Technology. "CVE-2015-9235 Detail." National Vulnerability Database. <https://nvd.nist.gov/vuln/detail/CVE-2015-9235> (accessed July 17, 2026).
6. MITRE Corporation. "CVE-2015-9235." CVE List. <https://www.cve.org/CVERecord?id=CVE-2015-9235> (accessed July 17, 2026).
7. National Institute of Standards and Technology. "CVE-2026-5450 Detail." National Vulnerability Database. <https://nvd.nist.gov/vuln/detail/CVE-2026-5450> (accessed July 17, 2026).
8. MITRE Corporation. "CVE-2026-5450." CVE List. <https://www.cve.org/CVERecord?id=CVE-2026-5450> (accessed July 17, 2026).
9. Cybersecurity and Infrastructure Security Agency. "Known Exploited Vulnerabilities Catalog." CISA. <https://www.cisa.gov/known-exploited-vulnerabilities-catalog> (accessed July 17, 2026).
10. All source code: <https://github.com/fredteumer/jhu-ai-eng-course/tree/main/module9>